



# Day 13 — Insider Threats

Incident Management · Week 8

**Cyber.SoHo Educational Hub**

*From the Industry to the Classroom — Building the IT's Future, Today and Together!*



# Where we are in the course

Week 8 · May 21 – May 22 · 4 hours

- Up to now: outsiders trying to get in
- From today: the threat may already be inside, with a valid badge and a payslip
- Today is the hinge class
- Next class (Class 2 of Week 8): Detecting & Eradicating Insider Activity

*The conversation with HR — which never happened in the malware lecture — suddenly becomes the most important conversation in the room.*



# Today's roadmap

## Five lessons in one hour

### 1. Define the three insider-threat profiles

*malicious · negligent · compromised*

### 2. Recognize behavioural and technical red flags

*behavioural + technical, correlated in a window*

### 3. Implement technical controls

*DLP · UEBA · access-rights monitoring*

### 4. Navigate legal, ethical, and HR considerations

*three gates before any investigation acts*

### 5. Describe a formal Insider Threat Program

*governance · five pillars · security-aware culture*



# A word before we begin

## On tone

- This material can feel uncomfortable
- The point is NOT paranoia
- The point IS:
  - Rules
  - Documentation
  - Cross-functional sign-off
  - Respect for the human on the other side of the alert

*Get these four right → insider-threat work is just regular incident response.  
Get them wrong → you become the news story.*



## LESSON 1

# The Three Profiles

*Malicious · Negligent · Compromised*



# Define the three insider-threat profiles

## CISA working definition

*An insider threat is the risk that someone with authorised access uses it — wittingly or unwittingly — to harm the organisation.*

**Two words to circle: wittingly ... unwittingly**

Half of all insider incidents are unwitting.  
That is where the three profiles come from.



# Profile 1 — Malicious insider

*Wants to do harm. Knows what they are doing.*

- Motive
  - Revenge, money, ideology, ego
- Typical triggers
  - Missed promotion · firing · recruitment by competitor
- Volume
  - Small
- Cost
  - IBM 2024 report: ~ US \$4.99M average per incident
- Defence focus
  - UEBA on resignation / firing windows
  - Just-in-time access
  - Tight off-boarding



## Profile 2 — Negligent insider

*No intent. Total carelessness.*

- Clicks phishing links
  - Plugs in the parking-lot USB
  - Forgets to encrypt the laptop
  - Ships the spreadsheet to the wrong distribution list
- 
- Volume
    - Largest by far — Ponemon: > 55 % of all insider events
  - Defence focus
    - Training · Safe defaults · Friction-removing controls
    - Don't punish — fix the tool





## Profile 3 — Compromised insider

*The user is asleep. An attacker wears their identity.*

- Looks normal from inside — the credentials are normal
- Acquired via:
  - Phishing
  - Infostealer malware
  - Session-cookie / token theft
- IBM X-Force: infostealer-driven credential theft is now a dominant vector
- Defence focus:
  - MFA (Multi-Factor Authentication)
  - EDR (Endpoint Detection & Response)
  - Impossible-travel detection
  - Conditional access / session controls



# Three stories (1/2)

*Same surface behaviour → very different responses*

## Story A — Tom in Sales

- Passed over for promotion in March
- Exports entire EMEA customer list Friday 19:42
- Resignation letter Monday morning

→ **MALICIOUS**

## Story B — Maria in Engineering

- 02:14 release push, downloads unencrypted DB backup to laptop
- Laptop pickpocketed on the train

→ **NEGLIGENT**



## Three stories (2/2)

### Story C — Igor in Marketing

- Clicks "CFO" email
- Enters credentials on microsoft365-secure (missing letter)
- Bucharest IP signs in as Igor
- Three weeks of insider trading on press releases

→ **COMPROMISED** — Igor did nothing himself

***The same access can be misused in three very different ways.  
Your defence must change with the profile.***



# The three profiles side by side

## The Three Insider-Threat Profiles

*Same access, very different intent — and very different defences*

### MALICIOUS



#### Intent

Deliberate. Wants to harm, steal, or profit.

#### Typical motives

- Revenge after firing
- Money / espionage
- Ideology, ego

#### Defence focus

UEBA, DLP, off-boarding, just-in-time access.

### NEGLIGENT



#### Intent

None. Just careless or untrained.

#### Typical behaviours

- Clicks phishing links
- Re-uses weak passwords
- Mis-shares files publicly

#### Defence focus

Training, friction-removing controls, safe defaults.

### COMPROMISED



#### Intent

None — the user is unaware. Attacker uses their account.

#### How it happens

- Stolen credentials
- Session-token theft
- Malware on laptop

#### Defence focus

MFA, EDR, impossible-travel detection, session controls.

*Cyber.SoHo Educational Hub · Day 13 — Insider Threats*



# Key Takeaway · Lesson 1



## KEY TAKEAWAY

Three profiles. Same access. Three different defences.

Asking 'what is an insider threat?' is the wrong question.  
The right question is 'which of the three — and what control answers it?'



## LESSON 2

# Red Flags

*Behavioural · Technical · Correlated*



# Recognize behavioural and technical red flags

## The principle to remember

*One red flag is gossip.  
Three correlated red flags in the same person,  
in the same window, across categories,  
— that is an investigation.*

*Two categories: behavioural (the human) and technical (the keyboard).*



# Behavioural red flags

*Observed by managers, colleagues, HR — not the SIEM*

- Sudden disgruntlement after a missed promotion
- Unusual hours on-site with no business reason
- Unexplained sudden affluence
- Resistance to security policies / MFA / mandatory vacation
- Open admiration or contact with a competitor
- Severe personal stressors + workplace withdrawal
- Resignation announced in last 60 days ← biggest single signal

*Carnegie Mellon CERT: highest-risk window is the last 30 days before leaving*





# Technical red flags

*Observed by DLP, UEBA, IAM*

- Mass downloads far above user baseline
- Personal USB drives on a corporate machine
- Outbound uploads to personal cloud (Dropbox, GDrive, Mega, WeTransfer)
- Logins outside normal hours / from new geographies
- Bulk emails to a personal address with attachments
- Access to systems outside the user's job role
- Tampering with EDR or DLP agents
- First-time use of dormant high-privilege account ← bright red flag



# The correlation rule

## When does the bell ring?

ONE behavioural flag

**= rumour**

ONE technical flag

**= noise**

BOTH, same user, same window

**= a case**

### The 'three flags' recipe

- Same user · same window (typically 7-14 days)
- Different categories — at least one behavioural + one technical



# Diego case · timeline (1/2)

*A fortnight in one engineer's life*

|             |                                                   |                           |
|-------------|---------------------------------------------------|---------------------------|
| 2 weeks ago | Heated conversation about missed team-lead role   | <i>behavioural</i>        |
| Sun 03:11   | Login from home IP                                | <i>technical · INFO</i>   |
| Wed 09:45   | Pulls 4.2 GB of code from GitLab                  | <i>technical · MEDIUM</i> |
| normal      | His normal weekly pull: ~ 800 MB                  | <i>context</i>            |
| DLP         | Files labelled internal-source-code/payment-rails | <i>data label</i>         |



## Diego case · timeline (2/2)

### The moment of correlation

Thursday 11:20

Uploads 4.1 GB to a personal Mega.nz account

→ Four flags · two categories · one user · ten-day window

### What the analyst does

- Does NOT call Diego
- Does NOT pull the manager into a meeting
- Opens the cross-functional investigation panel (Lesson 4)

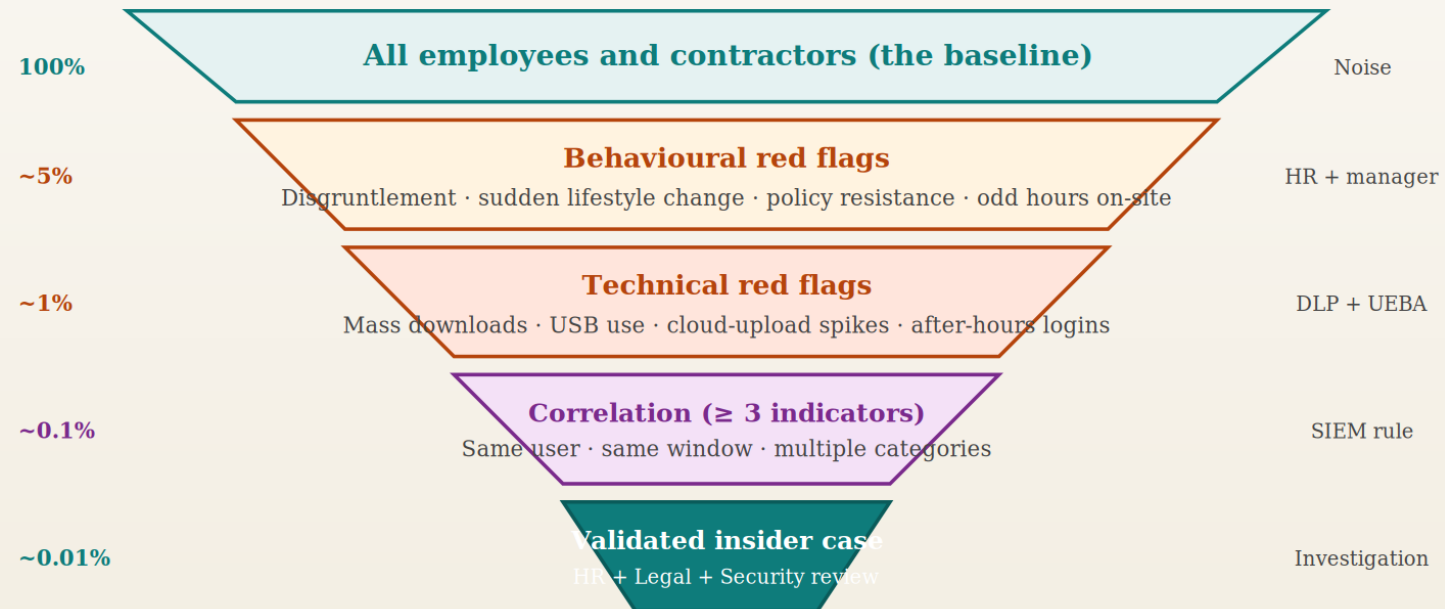
*That difference = staying out of the newspaper*



# The red-flag funnel

## Insider Red-Flag Funnel

*From a noisy crowd of signals to a small, defensible case*



### Key principle

A single red flag is gossip. Three correlated red flags in the same person, in the same window, across categories — that is when you escalate.



## Key Takeaway · Lesson 2



### KEY TAKEAWAY

Singles are gossip. Combinations are cases.

Behavioural + technical + same window → escalate.  
Anything less → keep watching, do not act.



## LESSON 3

# Technical Controls

*DLP · UEBA · Access-rights monitoring*



# Implement technical controls for insider-threat detection

Three pillars. Each one watches a different thing.



*No pillar alone is enough. The SIEM glues them.*





# Pillar 1 — DLP

*Data Loss Prevention — watches DATA*

- Reads actual content moving on network, email, endpoint, cloud
- Matches against policy:
  - Credit-card numbers
  - Source code
  - Classified labels
  - PII subject to GDPR · PIPEDA · HIPAA · SOX
- Verbs: block · quarantine · alert

*⚠ A noisy blocking rule is worse than no DLP — the team turns it off by Friday.*



## Pillar 2 — UEBA

*User & Entity Behaviour Analytics — watches PEOPLE*

- Learns each user's normal · scores deviations
- Per-user fingerprint, not a global threshold
- Axes: time of day, day of week, geo, asset, volume, peer group, sequence
- Flags RELATIVE behaviour, not absolute

**z-score formula**

$$z = (\text{today} - \text{mean}) \div \text{stdev}$$

*$z \geq 3$  = classic alert threshold*



## Pillar 3 — Access monitoring

### *Watches RIGHTS*

- IAM (Identity & Access Management) — central directory, SSO
- IGA (Identity Governance & Administration) — periodic re-certification
- PAM (Privileged Access Management) — break-glass admin accounts

### **Principle of LEAST PRIVILEGE (NIST SP 800-53)**

- Grant the minimum necessary
- Re-prove necessity on a schedule

*Dormant high privilege is one of the top three predictors of an insider incident.*



# Eve at Banco Atlántico (1/2)

*Three pillars firing in sequence on ONE user*

|         |                                                     |                      |
|---------|-----------------------------------------------------|----------------------|
| 08:55   | Logs in from her usual office laptop                | <i>IAM: normal</i>   |
| ongoing | Still has dormant HR-records permission from week 1 | <i>context</i>       |
| 09:12   | Runs first-ever query against HR records            | <i>UEBA fires</i>    |
| UEBA    | z-score jumps from 0 to ~60                         | <i>off the chart</i> |
| →       | Two pillars now talking to each other               |                      |



## Eve at Banco Atlántico (2/2)

09:14

Runs `SELECT * FROM employee_salaries`

*DLP labels it hr-pii-confidential*

DLP

Blocks the export

*third pillar fires*

09:14:30

SIEM correlation rule fires

*ticket → ITP team*

auto

Permission silently reduced to read-only-on-self

*no confrontation*

### Outcome

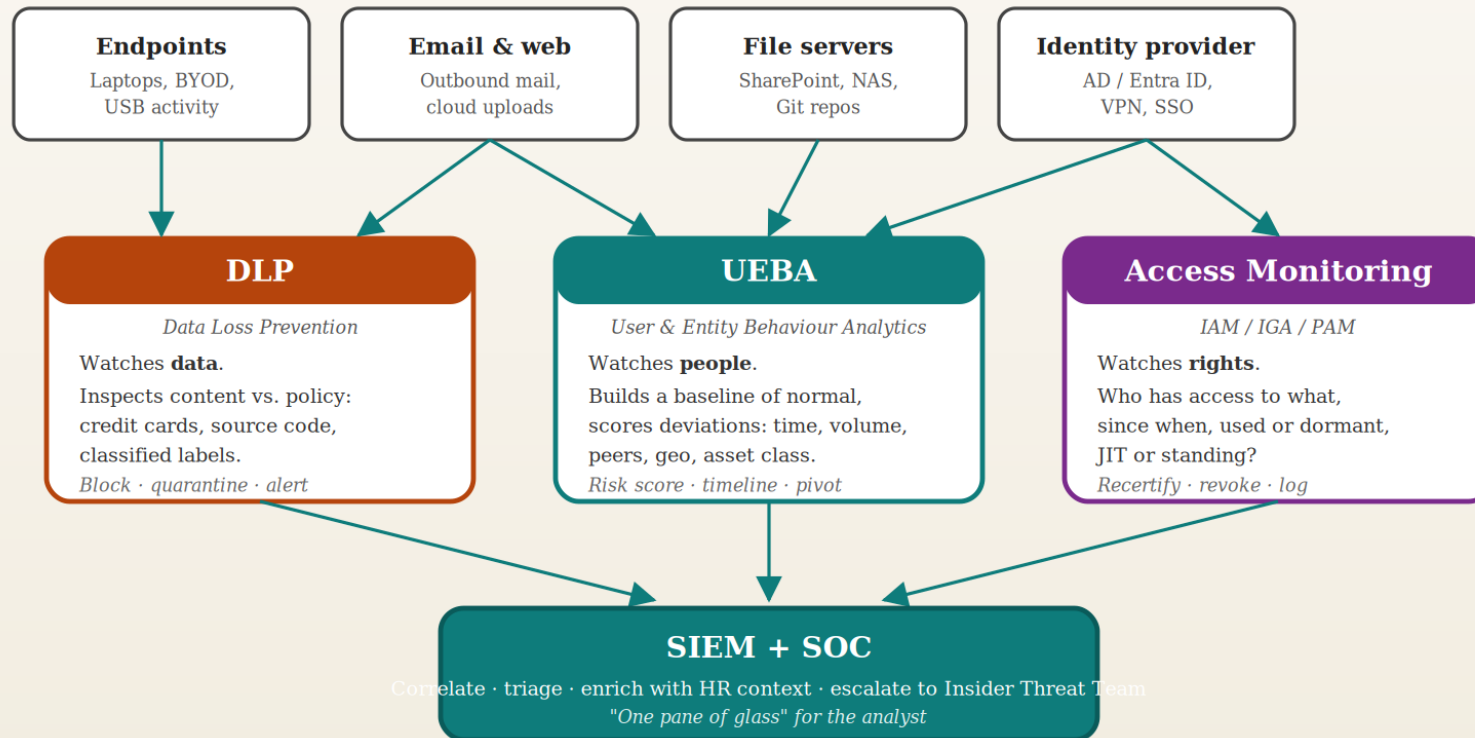
Breach prevented · intern never humiliated in public  
Backstory: offered € 500 on Telegram to 'just look up salaries'



# Architecture — how the three pillars connect

## Three Pillars of Insider-Threat Tech: DLP · UEBA · Access Monitoring

*Where they sit, what they see, and how they hand off to the SOC*



Cyber.SoHo Educational Hub · Day 13 — Insider Threats



# Severity ladder — combining the pillars

*How many pillars fired = how loud the alarm*

| Pillars firing                                    | Severity |
|---------------------------------------------------|----------|
| $z \geq 3$ + sensitive DLP label + dormant access | CRITICAL |
| $z \geq 3$ + sensitive DLP label                  | HIGH     |
| $z \geq 3$ OR sensitive DLP label                 | MEDIUM   |
| None of the above                                 | INFO     |

*This small, auditable ladder is your detection policy.*



## Key Takeaway · Lesson 3



### KEY TAKEAWAY

DLP watches data. UEBA watches people. Access monitoring watches rights.

Alone, each is a noisy alarm.

Together they are a defensible case file.





## LESSON 4

# Legal • Ethical • HR

*The three gates before any investigation acts*



# Navigate legal, ethical, and HR considerations

## The core rule of this lesson

*The moment an alert points at a named human,  
every subsequent action must pass three gates:*

 **LEGAL**    **ETHICAL**    **HR**

*...and you must prove, in writing, that all three were cleared.*



# Why this matters

*Doing it badly produces real headlines*

- Wrongful-dismissal lawsuit
- GDPR / PIPEDA fine from the regulator
- Union arbitration
- Journalist gets the story
- Innocent employee self-harms because the company humiliated them in public — before checking facts

*An insider-threat investigation is an investigation into a colleague's conduct.*



## Legal gate

### *Questions to answer before acting*

- Documented lawful basis to monitor?
- Did the employee accept monitoring (contract / banner)?
- Action permitted by applicable law?
  - GDPR (EU) · PIPEDA (CA) · CCPA / CPRA (US-CA)
- Evidence chain of custody: who · when · hashes · sealed storage
- Works-council / union notified where required (FR, DE, NL ...)
- Counsel signed off IN WRITING



# Ethical gate

## *Questions to answer before acting*

- Proportional to suspicion?
- Least-intrusive method that still answers the question?
- Bias check — are we scrutinising one group disproportionately?
- Reversible until guilt is established?
- Dignity of the employee preserved at every step?

*Each question has a concrete operational answer that goes in the case file.*



## HR gate

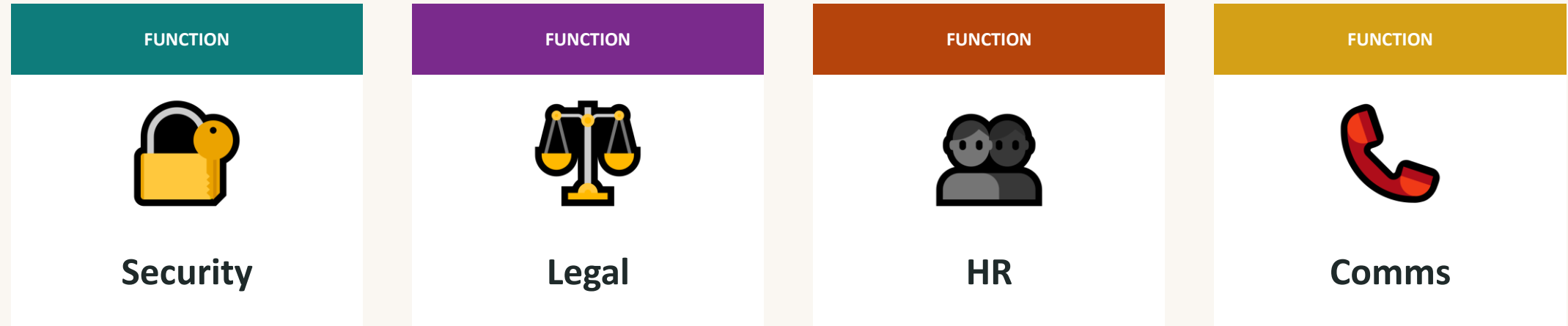
### *Questions to answer before acting*

- Performance record reviewed — outlier or pattern?
- EAP (Employee Assistance Programme) considered as first option?
- Disciplinary procedure followed step by step?
- Manager briefed need-to-know only — and told NOT to confront
- Communications plan for the team if action becomes visible



# The cross-functional panel

*The only acceptable forum for investigative decisions*



*(Manager joins LATER, on legal advice.)*

Named in ISO/IEC 27035 and the CISA Insider Threat Mitigation Guide.

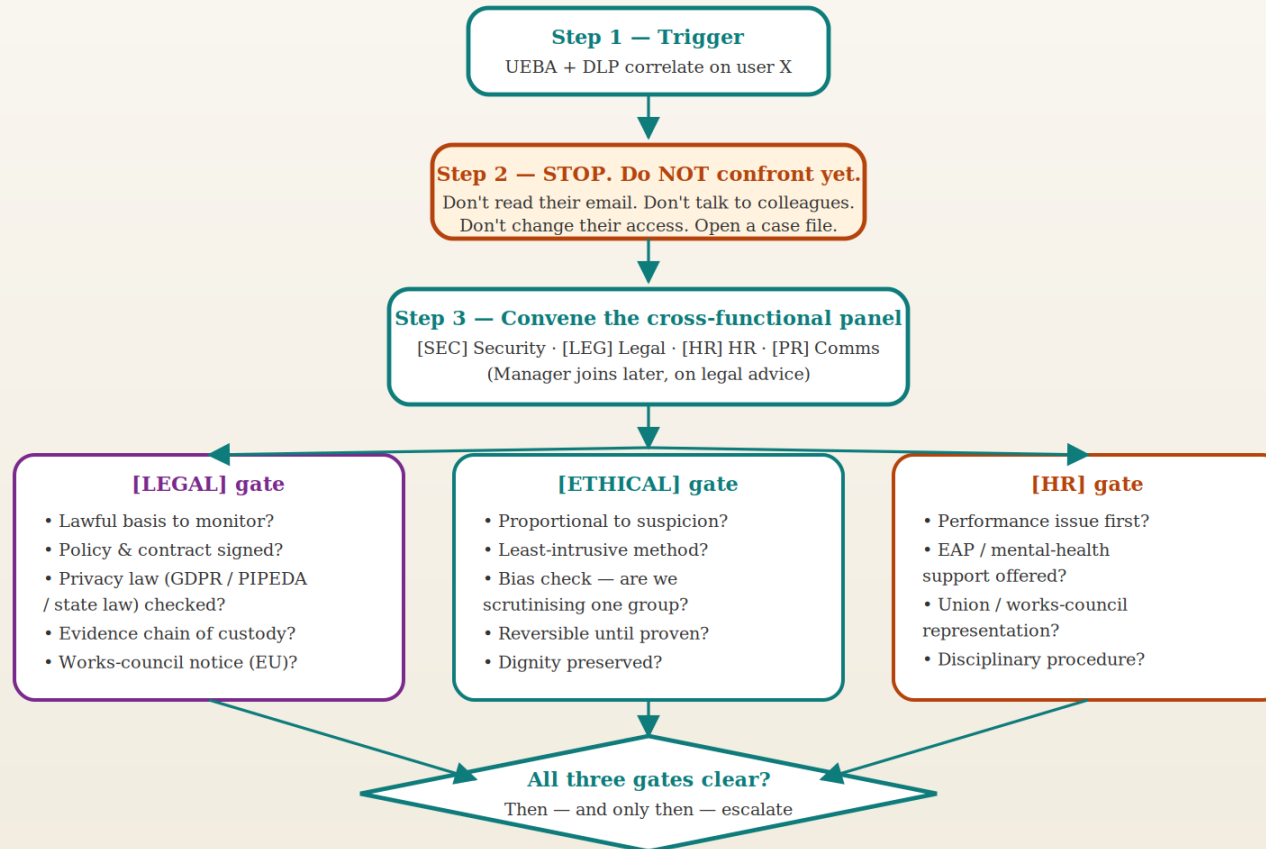
***No single function gets to fire alone.***



# The decision tree

## Investigating an Employee — The "Stop & Think" Decision Tree

*Same alert, very different rules depending on jurisdiction, role and what you actually plan to do*



*Cyber.SoHo Educational Hub · Day 13 — Insider Threats*





## Key Takeaway · Lesson 4



### KEY TAKEAWAY

No single function gets to fire alone.

Three gates · four functions · one panel.  
If any gate fails, you do not escalate.



## LESSON 5

# The Program

*Insider Threat Program + Security-aware culture*



# Describe the components of a formal ITP

An ITP is NOT a tool. It is a sustained program.

Layer 1

**Executive sponsor & governance**

*the roof*

Layer 2

**Five operational pillars**

*the structure*

Layer 3

**Security-aware culture**

*the foundation*



# Layer 1 — Governance

*One named executive owns the program*

- Typical sponsor:
  - CISO (Chief Information Security Officer)
  - CRO (Chief Risk Officer)
  - or General Counsel
- Owns:
  - The charter
  - The budget
  - The board-level annual report
  - The risk appetite

*Without the sponsor, the program dies the next time the budget is squeezed.*



## Layer 2 — Five pillars (1/2)

*All verbs*

### 1. Define

what counts as 'insider', crown jewels, risk tolerance, roles, signed policies

### 2. Detect

DLP · UEBA · IAM + tip line + manager training + periodic audits

### 3. Assess

the cross-functional panel · evaluates BEHAVIOURS, not profiles (CISA is explicit)



## Layer 2 — Five pillars (2/2)

### 4. Manage

intervene early · reversible actions first · EAP referral · discipline by the book · clean off-boarding

### 5. Learn

post-incident review on every closed case · update detections, training, policies · share anonymised lessons

*A program without a Learn pillar gets exactly the same incident again next quarter.*



## Layer 3 — Culture (1/2)

### *Seven traits of a healthy culture*

- Trust + verify
  - Assume good faith. Build controls anyway.
- Psychological safety
  - Concerns raised without retaliation fear.
- Just-culture model
  - Borrowed from aviation: mistakes coached, only deliberate harm punished.
- Manager involvement
  - First-line manager = most important detector.



## Layer 3 — Culture (2/2)

- Awareness training
  - Annual · role-specific · NOT a 30-min video
- Onboarding & off-boarding
  - Day 1 and last day = riskiest moments · scripted, not improvised
- Wellbeing & EAP
  - Many incidents trace to addiction, mental health, personal crisis
  - A funded EAP costs a fraction of ONE prevented incident





# The ITP, in one picture

## The Insider Threat Program (ITP) — a Living Organism

*Governance on top · cross-functional team in the middle · culture as the bedrock*

### Executive sponsor & governance

Charter · budget · annual board reporting · risk appetite

#### Define

- What counts as "insider"
- What assets are crown jewels
- Risk tolerance
- Roles & RACI
- Policies signed by all

#### Detect

- DLP · UEBA · IAM
- SIEM correlations
- Hotline / tip line
- Manager training to spot warning signs
- Periodic audits

#### Assess

- Cross-functional panel
- Severity scoring
- Behaviour, not profile
- Legal & ethical gates
- Evidence preservation
- Documented decisions

#### Manage

- Intervene early
- Reversible actions first
- EAP referral
- Discipline OR support
- Termination & off-boarding script

#### Learn

- Post-incident review
- Update detections
- Update policies
- Update training
- Share lessons (anonymised)

### Security-aware workplace culture (the foundation)

#### Trust + verify

Assume good faith.  
Build controls anyway.

#### Psychological safety

People raise concerns without fear.

#### Just-culture model

Mistakes ≠ crimes.  
Patterns get coached.

#### Manager involvement

First line of detection and support.

#### Awareness training

Yearly, role-specific, not a 30-min video.

#### Onboarding & off-boarding

Day 1 and last day are the riskiest moments.

#### Wellbeing & EAP

Healthy people make healthier decisions.

#### Anonymous reporting

A tip line that actually gets read.

*CyberSoHo Educational Hub · Day 13 — Insider Threats*



# Monthly health metrics — RAG (Red/Amber/Green)

*Five numbers, traffic-light coloured, every month*

| Metric                                | Green target          |
|---------------------------------------|-----------------------|
| Annual awareness training completion  | ≥ 95 %                |
| Privileged access re-certified < 90 d | ≥ 90 %                |
| Mean time to panel                    | ≤ 1 day               |
| Off-boarding access revoked < 24 h    | ≥ 95 %                |
| Anonymous tip count                   | non-zero, non-extreme |

*Boring rituals keep the program funded.*



## Key Takeaway · Lesson 5



### KEY TAKEAWAY

An ITP is not a tool. It is a living program.

Governance on top.

Define · Detect · Assess · Manage · Learn in the middle.

Culture as the foundation.



## THE ONE SENTENCE TO REMEMBER

*Insider threats are not a tool problem.*

*They are a people problem solved by  
tools, by process, by law and by culture*

*— in that order, all at once,  
with a panel of grown-ups in the room.*



# For tomorrow's class

## Class 2 of Week 8 · Detecting & Eradicating Insider Activity

- Bring a laptop with PowerShell or Python ready
- Read the CISA Insider Threat Mitigation Guide tonight
- Pair work on a real dataset
- Produce an actual case file with artefacts



# Key references

## Standards & government bodies

- CISA — Insider Threat Mitigation · [cisa.gov/topics/physical-security/insider-threat-mitigation](https://cisa.gov/topics/physical-security/insider-threat-mitigation)
- NIST SP 800-53 · [csrc.nist.gov/publications/detail/sp/800-53/rev-5/final](https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final)
- ISO/IEC 27035 · [iso.org/standard/78973.html](https://iso.org/standard/78973.html)
- Carnegie Mellon CERT Insider Threat Center · [insights.sei.cmu.edu/insider-threat/](https://insights.sei.cmu.edu/insider-threat/)

## Always scan unfamiliar links

- VirusTotal · URL scanner · [virustotal.com/gui/home/url](https://virustotal.com/gui/home/url)



## Disclaimer (in short)

- Intellectual Property of Cyber.SoHo Educational Hub
- No affiliations with any organisation named in this material
- YouTube videos are linked, not embedded — copyright holders' channels
- Material is educational — not legal or professional advice
- Conduct regulated by:
  - Ley Orgánica 10/1995 (Spanish Penal Code)
  - EU Directive 2013/40/EU (attacks against information systems)
  - Canadian Criminal Code s. 342.1 (unauthorised use of a computer)
  - US CFAA 18 U.S.C. § 1030
- Scan every external URL on VirusTotal before opening on a corporate machine

© Cyber.SoHo Educational Hub



# Thank you.

 **Cyber.SoHo Educational Hub**

*From the Industry to the Classroom — Building the IT's Future, Today and Together!*